Packet Tracer – Étudier le paysage des menaces

Objectifs

Partie 1: Analysez une vulnérabilité liée à la configuration du réseau

Partie 2: Analysez la vulnérabilité d'un malware par phishing

Partie 3: Analyser une vulnérabilité du réseau sans fil et du DNS

Contexte/scénario

Le paysage des menaces comprend toutes les vulnérabilités qui peuvent être exploitées par les hackers. Chaque incident lié à la cybersécurité implique l'exploitation de vulnérabilités par différents types de hackers. Certains hackers veulent de l'argent, d'autres veulent être connus et d'autres encore veulent détruire les informations et l'infrastructure.

Dans cette activité, vous allez étudier trois vulnérabilités qui peuvent être exploitées par les hackers.

Remarque: Dans cette activité, les sites Data Center et ISP/Telco sont verrouillés.

Instructions

Partie 1: Analyser une vulnérabilité de configuration réseau

Parfois, les vulnérabilités de sécurité du réseau peuvent se produire par accident. Par exemple, oublier de mettre à jour le serveur ou le logiciel hôte peut exposer des vulnérabilités connues qui pourraient facilement être atténuées par une simple mise à jour. De même, des vulnérabilités peuvent apparaître lorsqu'un périphérique réseau n'est pas configuré correctement ou qu'un périphérique est défectueux. Dans cette section, vous allez explorer une vulnérabilité qui résulte d'un périphérique qui n'est pas correctement configuré avec les bonnes pratiques de sécurité.

Étape 1: Utilisez un réseau invité pour accéder aux autres périphériques du réseau.

a. À **Greenville**, localisez le **Smartphone 3** juste à l'extérieur de l'emplacement du **Home** (Domicile).

   Marie est la propriétaire de ce smartphone. C'est une amie de Bob qui vit dans la maison. Marie étudie pour obtenir un emploi dans le domaine de la cybersécurité et connaît bien les tests de pénétration du réseau. Elle a remarqué qu'un réseau sans fil invité est ouvert et accessible à tous. Elle s'est connectée au réseau invité et a utilisé Nmap pour lancer une analyse qui permet d'identifier et de découvrir des informations sur tous les périphériques actifs. L'un des périphériques semble être une webcam. Son adresse IP est 192.168.100.101.

b. Cliquez sur **Smartphone 3**, puis sur **Command Prompt** (Invite de commandes). Entrez la commande **ping 192.168.100.101**. Après un ou deux messages indiquant que la demande a expiré, les requêtes ping restantes doivent aboutir.

   Marie informe Bob que le réseau est très vulnérable aux attaques. Par exemple, quelqu'un peut prendre le contrôle de la webcam et regarder la vidéo depuis la maison. Bob invite Marie à venir étudier le problème et à proposer une solution.

Étape 2: Explorez le réseau Home (domestique) pour identifier la vulnérabilité.

a. Cliquez sur **Home**. Sachant que les routeurs domestiques contrôlent généralement les réseaux domestiques sans fil, Marie se dirige directement vers le bureau à domicile et s'assoit derrière le bureau. Elle utilisera le **Home Office PC** (PC du bureau à domicile) pour se connecter au routeur. Mais elle doit d'abord déterminer l'adresse IP.

© 2017 Cisco et/ou ses filiales. Tous droits réservés. Ceci est un document public de Cisco.

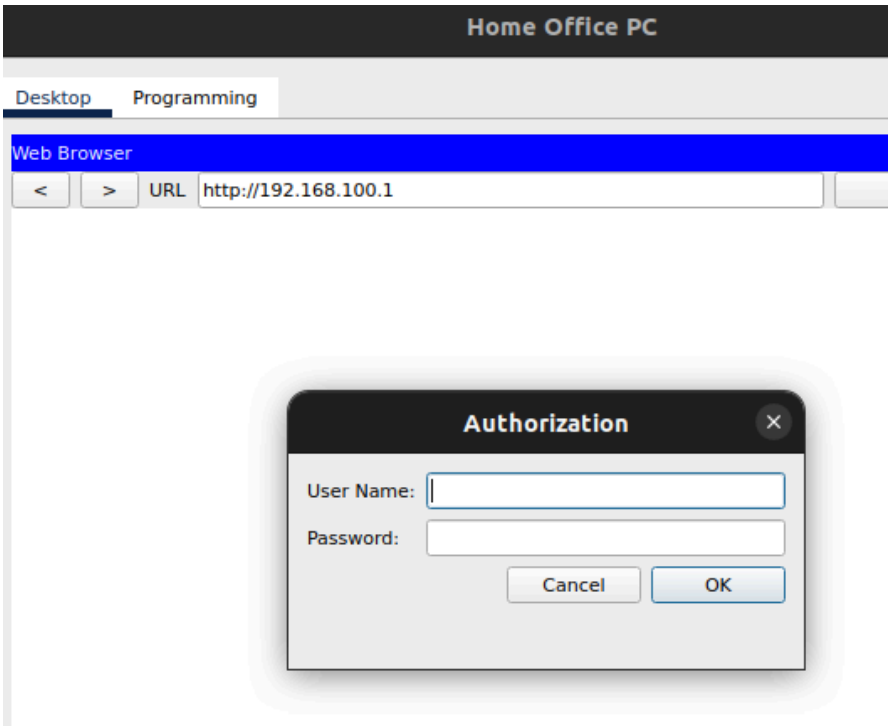
b. Cliquez sur **Home Office PC** (PC de bureau à domicile) > **Desktop** tab (onglet Bureau) > **Command Prompt** (Invite de commandes), puis entrez la commande **ipconfig**.

La passerelle par défaut est l'adresse IP du **Home Wireless Router** (routeur sans fil domestique).

Quelle est l'adresse IP utilisée?

```
C:\>ipconfig

FastEthernet0 Connection:(default port)

   Connection-specific DNS Suffix..:
   Link-local IPv6 Address.........: FE80::20A:F3FF:FE25:A89D
   IPv6 Address....................: ::
   IPv4 Address....................: 192.168.100.105
   Subnet Mask.....................: 255.255.255.0
   Default Gateway.................: ::
                                     192.168.100.1

Bluetooth Connection:

   Connection-specific DNS Suffix..:
   Link-local IPv6 Address.........: ::
   IPv6 Address....................: ::
   IPv4 Address....................: 0.0.0.0
   Subnet Mask.....................: 0.0.0.0
   Default Gateway.................: ::
                                     0.0.0.0
```

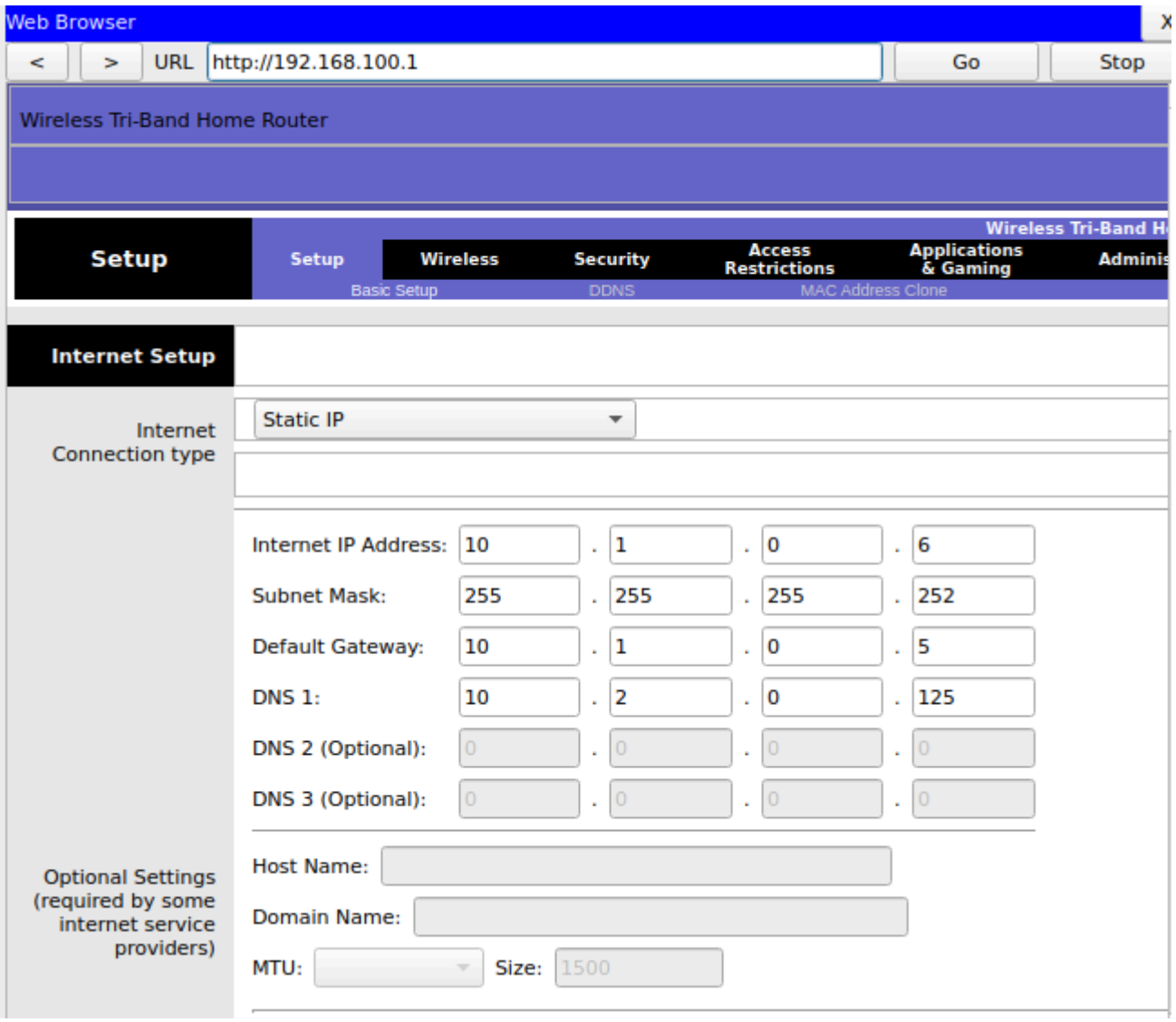
c. Ensuite, Marie utilise le **Web Browser** (Navigateur Web) pour se connecter au **Home Wireless Router** (routeur sans fil domestique). Fermez la fenêtre d' **invite de commande** et cliquez sur **Navigateur Web**. Saisissez l'adresse IP de la passerelle par défaut.



© 2017 Cisco et/ou ses filiales. Tous droits réservés. Ceci est un document public de Cisco.

d. Bob ne dispose pas de la documentation relative au routeur et ne connaît pas les informations d'identification. Marie recherche le modèle de routeur sur Internet et découvre que les informations d'identification par défaut utilisent **admin** pour le nom d'utilisateur et le mot de passe. Connectez-vous au **Home Wireless Router** (routeur sans fil domestique).

Capture d'écran de votre connexion au routeur :



© 2017 Cisco et/ou ses filiales. Tous droits réservés. Ceci est un document public de Cisco.

e. Cliquez sur **Wireless** (Sans fil). Passez en revue **Basic Wireless Settings** (les paramètres sans fil de base) pour chacune des trois radios qui font partie du routeur sans fil.

Lesquelles des radios sont actives ?

Elles sont toutes actives.

Quels sont les SSID attribués à ces radios ?

HomeNet pour le 2.4GHz et le 5GHz 2 et Guest pour 5GHz 1.

f. Click the **Wireless Security** submenu. Cliquez sur le sous-menu **Wireless Security (**Sécurité sans fil).

La sécurité est-elle activée pour chacune des radios? Les phrases secrètes sont-elles définies ?

Pour le 2.4GHz et le 5GHz 2, la sécurité WPA2 est activée.

Mais pas pour le 5GHz 1.

g. Marie a pu accéder au réseau de l'extérieur sans se connecter ; par conséquent, elle enquête plus avant. Cliquez sur le sous-menu **Guest Network** et examinez les paramètres.

Le réseau invité est-il actif? Si oui, sur quelle radio ?

Sur 5GHz 1 seulement.

Un réseau invité sans fil ne doit fournir un accès à Internet qu'aux invités. Il ne doit pas permettre aux invités d'accéder aux périphériques sur le réseau local à l'intérieur de la maison. Dans ce cas, les invités peuvent accéder au réseau local. Cela indique que le routeur domestique est mal configuré.

Que proposeriez-vous à Bob de faire pour sécuriser ce réseau ?

Je propose à Bob de sécuriser toutes les radios avec WPA2/WPA3, isoler le réseau invité et maintenir le routeur à jour.

© 2017 Cisco et/ou ses filiales. Tous droits réservés. Ceci est un document public de Cisco.

Partie 2: Enquêter sur la vulnérabilité d'un logiciel malveillant de phishing

Le phishing est un type d'attaque par ingénierie sociale où un hacker se fait passer pour une source légitime et fiable afin de vous inciter à installer un malware sur votre terminal ou à partager des informations personnelles ou financières. Les attaques par phishing proviennent généralement d'e-mails ou d'appels téléphoniques. Contrairement aux autres vulnérabilités du réseau, la principale vulnérabilité des attaques par phishing concerne les utilisateurs du réseau. Pour cette raison, une défense importante contre le phishing consiste à former les utilisateurs à la prévention des exploits par phishing.

Dans cette partie, vous allez simuler et analyser une attaque par phishing.

Remarque: Cette activité est uniquement destinée à des fins de démonstration. La rédaction et l'envoi d'e-mails de phishing sont contraires à l'éthique et sont considérés comme des attaques criminelles dans la plupart des juridictions.

Étape 1: Se faire passer pour un hacker et créer un e-mail de phishing.

a. Naviguez vers le réseau du Cafe

b. Cliquez sur Cafe Hacker Laptop > onglet Bureau > Email.

c. Cliquez sur Compose.

Utilisez votre imagination pour écrire un e-mail de phishing. Votre objectif est de convaincre l'utilisateur de copier et de coller une URL à partir de votre e-mail dans son navigateur. Incluez le lien **pix.example.com** dans l'e-mail. Vous pouvez consulter par exemple les e-mails de phishing en ligne pour voir comment les hackers écrivent ce type d'e-mails.

Remarque: les liens contenus dans les e-mails de phishing sont généralement des liens actifs. Tout ce que la victime a à faire est de cliquer dessus. Cependant, Packet Tracer ne prend pas en charge l'utilisation de liens actifs dans le client de messagerie.

Copie de l'e-mail envoyé :

Objet : WOOOW!!! T'as GAGNIER un LAMMA + 1000€ !! Cliq aps c'est urgant !!!

slt toi,

OMG t le first a aitre tirrer au sorre dans nautre graaaand con-cours secrait 🤩
felicitaçion ta gagner *un LAMMA VIRTUELLE + 1000€ en bon dacha* (ou un paquais de chips, ce-lon ta dispo).

Pour recuperrer ta recomense, ctrl C/ ctrl V exactemen pix.example.com dans la bar d'addrece de ton naviguateur UNIQUEMENT DANS L'ENVIRRONEMENT DE FORMACION.

Depaiche toi!! ci-non le lamma va senvoler vert marss 🚀

Bisou et a+
Laiquipe super top de PIX-PAY
pix-payeux@pix-payments.example

© 2017 Cisco et/ou ses filiales. Tous droits réservés. Ceci est un document public de Cisco.

d. Envoyez votre e-mail à trois personnes au sein du réseau de la **Branch Office** (succursale). Leurs adresses e-mail sont les suivantes:

- user1@mail.isp.net
- user2@mail.isp.net
- user3@mail.isp.net

Étape 2: Ouvrez les e-mails envoyés par le hacker.

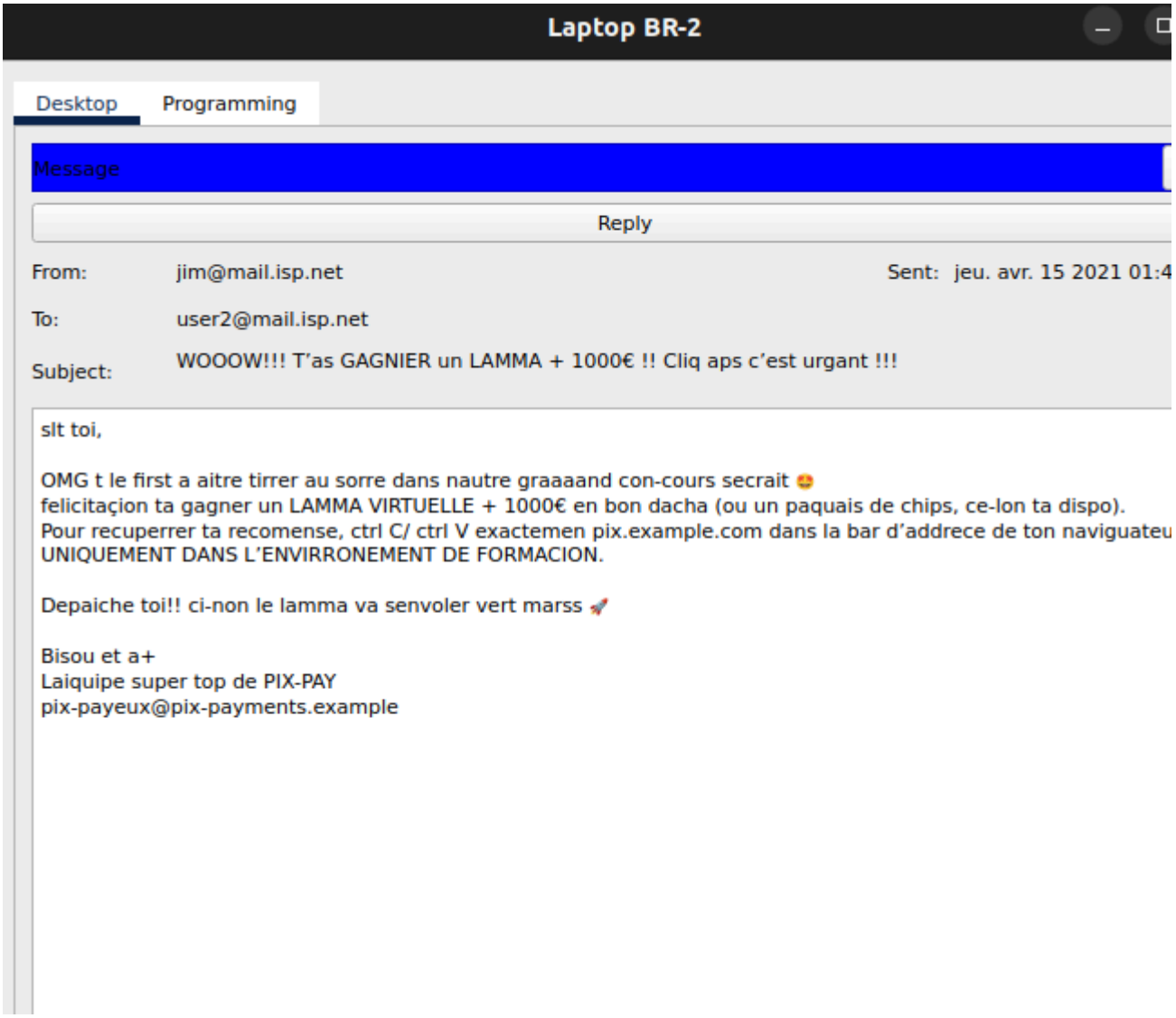
a. Accédez à la **succursale**.

b. Cliquez sur l'un des périphériques, soit **PC-BR1**, **Laptop BR-1** soit **Laptop BR-2**.

c. Cliquez sur l'onglet **Desktop** > **Email**, puis cliquez sur **Receive**. Vous devriez recevoir l'e-mail que vous venez d'envoyer.

Remarque: Packet Tracer peut prendre jusqu'à une minute pour converger. Vous devrez peut-être cliquer sur **Receive** (Recevoir) plusieurs fois si l'e-mail n'est pas récupéré.

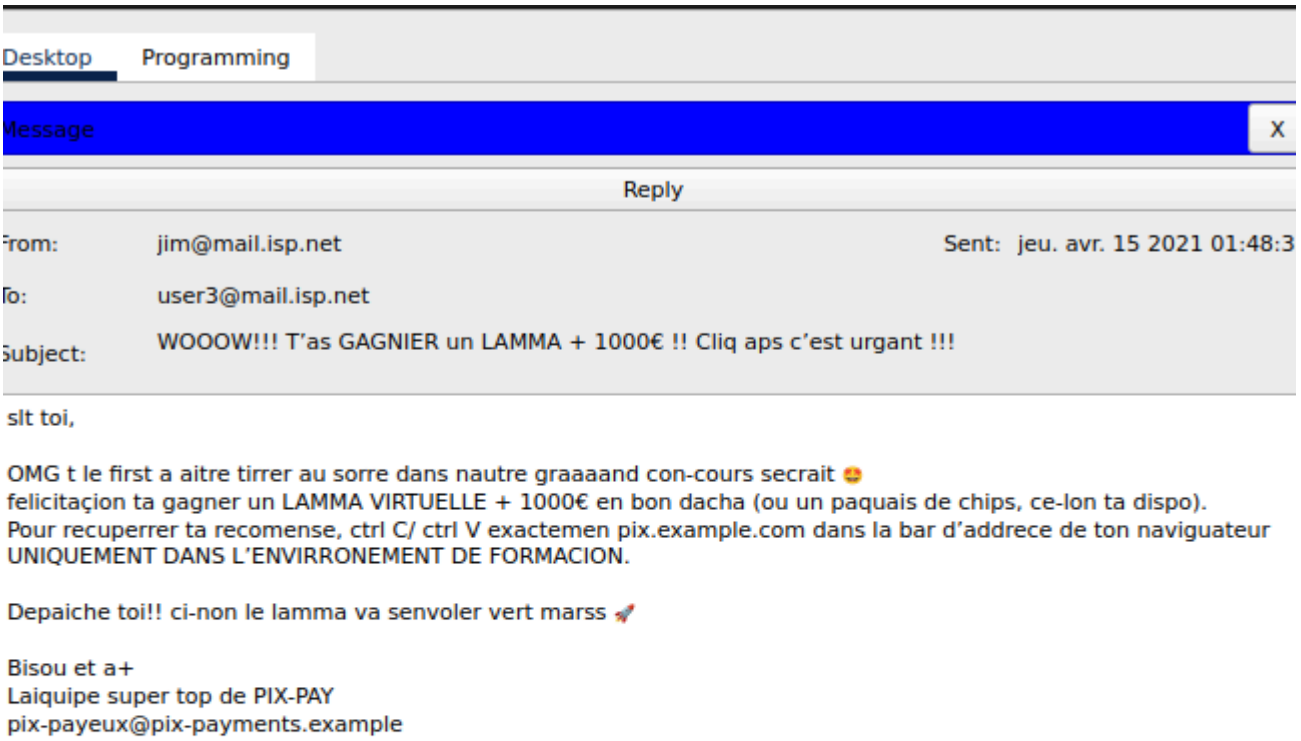
Copie d'écran de l'e-mail reçu :



© 2017 Cisco et/ou ses filiales. Tous droits réservés. Ceci est un document public de Cisco.

d. Facultatif: Accédez aux périphériques des autres victimes, ouvrez leur **Email** client (client de messagerie) et cliquez sur **Receive** (Recevoir) pour vérifier qu'ils ont également reçu votre e-mail de phishing.

Copie d'écran de l'e-mail reçu :



© 2017 Cisco et/ou ses filiales. Tous droits réservés. Ceci est un document public de Cisco.

Étape 3: Se faire passer pour une victime et suivre les instructions de phishing.

a. Lisez l'e-mail et copiez l'adresse du site web.

Adresse du site WEB : pix.example.com

b. Fermez la fenêtre **Mail Browser** (Navigateur de messagerie), puis cliquez sur **Web Browser** (Navigateur Web).

c. Collez l'URL dans le champ **URL**, puis **Go**.

Remarque: Packet Tracer peut prendre jusqu'à une minute pour converger. Vous pouvez cliquer sur **Fast Forward** (Avance rapide du temps) (Alt+D) pour accélérer le processus.

Que s'est-il passé lorsque la page web s'est chargée ?

Il y a marquer que mes fichiers son encrypter et que le seul moyen de les recuperer et des payer une rançon

De quel type d'attaque s'agit-il ?

C'est une attaque d'ingénierie sociale.

Dans une situation réelle, cet e-mail est généralement propagé par un virus qui envoie automatiquement des e-mails malveillants à toutes les adresses de votre liste de contacts.

Décrivez les dommages que ce type d'attaque peut causer au sein d'une entreprise ?

Vole de données (celles des clients mais aussi des employés).

Les collaborateurs doivent être formés à l'identification des e-mails de phishing et aux mesures à prendre pour éviter tout dommage. En outre, les entreprises peuvent configurer des pare-feu, des systèmes de prévention des intrusions et d'autres périphériques et logiciels de sécurité pour bloquer les e-mails de phishing avant leur entrée sur le réseau. Certaines entreprises s'abonnent à des services qui compilent et gèrent des listes de sites web malveillants. Les périphériques de sécurité de l'entreprise peuvent ensuite utiliser ces listes pour mettre à jour automatiquement les filtres afin de bloquer le trafic malveillant.

© 2017 Cisco et/ou ses filiales. Tous droits réservés. Ceci est un document public de Cisco.

Partie 3: Examiner un réseau sans fil et une vulnérabilité DNS

L'utilisateur moyen du réseau a tendance à faire confiance aux réseaux Wi-Fi ouverts dans les lieux publics. En utilisant le Wi-Fi à la place des services de données cellulaires, vous pouvez fournir des débits de données plus rapides et être plus économiques. Cependant, les hackers peuvent configurer un ordinateur portable avec une interface Wi-Fi qui peut servir à la fois de point d'accès Wi-Fi et de client Wi-Fi. Cela signifie que les hackers peuvent créer leurs propres réseaux sans fil et diffuser un SSID convaincant aux victimes potentielles dans les lieux publics. Les hackers utilisent ces points d'accès non autorisés pour lancer des attaques de type « main-in-the-middle ». Lors de cette attaque, les hackers peuvent capturer et lire tout le trafic sans fil des périphériques qui s'associent au point d'accès non autorisé, et peuvent ainsi découvrir des noms d'utilisateur, des mots de passe et d'autres informations confidentielles.

Dans cette partie, vous allez étudier comment un point d'accès non autorisé peut être utilisé pour inciter les utilisateurs à se connecter à un faux réseau sans fil. Lorsqu'ils sont combinés avec des services réseau tels que DHCP et DNS, les utilisateurs peuvent être victimes d'attaques de sites web malveillantes par le biais de détournements DNS.

Étape 1: Connectez-vous au réseau sans fil de l'auteur de la menace.

a. Accédez au **Cafe** (café). Remarquez le hacker assis dans un coin.

b. Cliquez sur le **Hacker Backpack** (sac à dos Hacker) et examinez son contenu. Dans son sac à dos, il a un routeur sans fil et un détecteur de réseau. Son objectif est d'intercepter le trafic des utilisateurs et de le diriger vers un serveur malveillant.

c. Retournez au **Cafe** (café) et cliquez sur l'ordinateur portable du **Cafe Customer** (client du café) > onglet **Desktop** (Bureau) > application **PC Wireless** (PC sans fil).

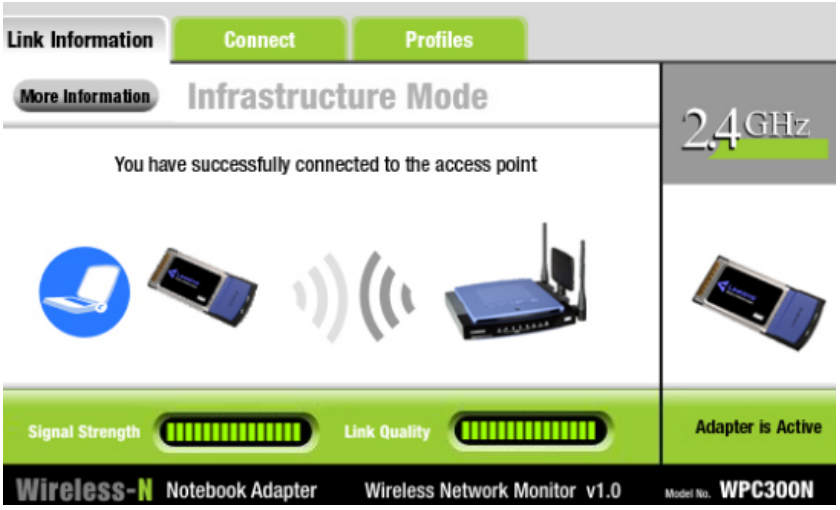
d. Cliquez sur l'onglet **Connect** (Connecter). Vous devrez peut-être cliquer sur **Refresh** (Rafraîchir) pour afficher la liste des réseaux sans fil disponibles.

Si vous étiez au café, à quel réseau sans fil choisiriez-vous de vous connecter ? Expliquez votre réponse.

Je choisirais le réseau Wi-Fi officiel et protégé du café (celui dont le personnel donne le SSID exact et le mot de passe), pas un réseau ouvert ni un réseau au nom suspect ou dupliqué.

e. Cliquez sur l'un des noms de réseau **Cafe_WI-FI_FAST**, puis cliquez sur **Connect** (Connecter).

Capture d'écran de votre connexion :



© 2017 Cisco et/ou ses filiales. Tous droits réservés. Ceci est un document public de Cisco.

Étape 2: Rendez-vous sur votre site de réseau social préféré.

a. Fermez l'application **PC Wireless** (PC sans fil) et cliquez sur **Web Browser** (Navigateur Web).

b. Dans le champ URL, saisissez **friends.example.com**, puis cliquez sur **OK**. Ce site web est censé être un réseau social légitime dans cette simulation.

Que s'est-il passé ?

Cette page de phishing c'est afficher lors de la connexion au site : http://friends.example.com étant donnée que le client est connecté à un réseau clone créé par le hacker.

Quelle était l'URL du serveur du malware qui a été utilisé dans le scénario de l'attaque par phishing? Est-ce la même chose ?

http://friends.example.com

Étape 3: Recherchez la source de l'attaque.

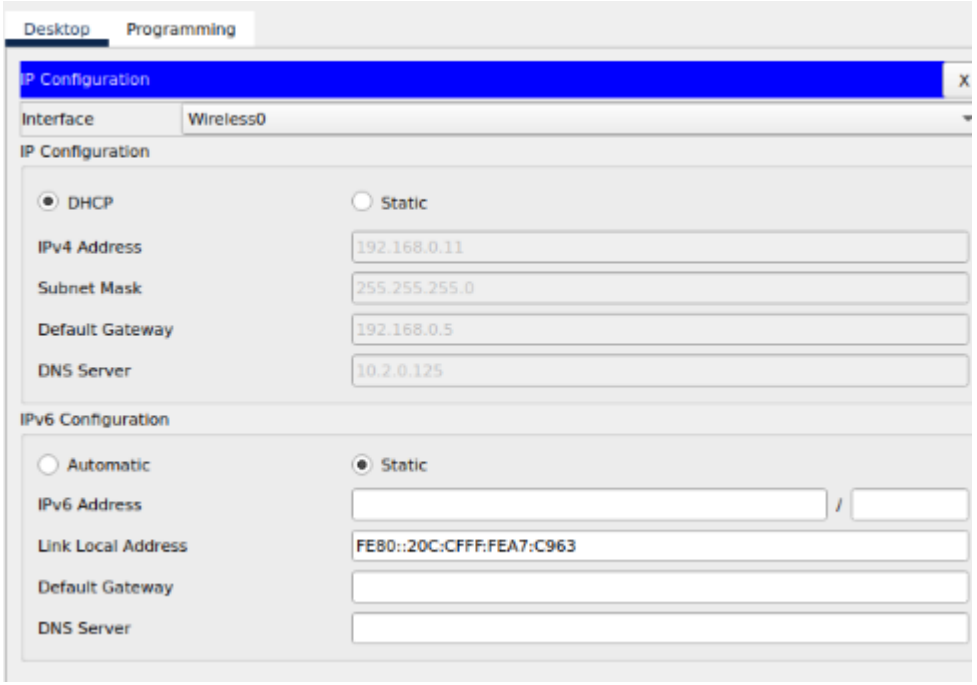
a. Fermez le **Web Browser** (navigateur Web) et cliquez sur **IP Configuration** (Configuration IP).

b. Dans le **Cafe** (café), cliquez sur **VPN Laptop** (Ordinateur portable VPN) > onglet **Desktop** (Bureau) > **IP Configuration** (Configuration IP).

c. Cliquez sur **Cafe Customer** dans votre barre des tâches pour le ré-afficher, puis organisez les deux fenêtres de **IP Configuration** (configuration IP) côte à côte. Comparez les valeurs entre les deux périphériques.

© 2017 Cisco et/ou ses filiales. Tous droits réservés. Ceci est un document public de Cisco.

Capture d'écran des deux fenêtres :



Quelles sont les différences entre les adresses des deux ordinateurs portables?

Les adresses ipv4 sont différente et la passerelle est différente, même chose pour le serveur DNS.

d. Enquêtez sur **Cafe Hacker Laptop** (l'ordinateur portable de hacker de café).

Quelle est son adresse IP ? Pourquoi est-ce important ?

192.168.10.199

Car le PC customer est dans le même réseau que le PC du hacker.

Sur **Cafe Hacker Laptop** (l'ordinateur portable de hacker de café), cliquez sur l'onglet **Services** > **DNS**.

e. Recherchez le nom du site Web **friends.example.com**. Notez que l'adresse IP est la même adresse IP que celle associée à **pix.example.com** lors de l'attaque de phishing précédente.

Adresse IP de pix.example.com :

© 2017 Cisco et/ou ses filiales. Tous droits réservés. Ceci est un document public de Cisco.

f. Sous **Services**, cliquez sur **DHCP**. Notez que l'adresse du serveur DNS distribuée aux hôtes via DHCP est la même que celle attribuée au **Cafe Customer** (client Cafe).

Quelles sont les étapes de cette attaque ?

Synthèse

Dans cette activité, nous avons examiné trois façons différentes dont les vulnérabilités peuvent conduire à des exploits. En tant qu'utilisateur du réseau ou professionnel de la cybersécurité, il est de votre responsabilité de réfléchir aux différentes manières de détecter et d'atténuer ces vulnérabilités avant qu'une cyberattaque se produise.

© 2017 Cisco et/ou ses filiales. Tous droits réservés. Ceci est un document public de Cisco.